

SCANNERIZZAZIONE DELLA RETE

OBBIETTIVO

Eseguire scansioni di rete, identificare vulnerabilità e valutare i rischi utilizzando strumenti standard di settore come Nmap e Nessus.

- Eseguire scansioni di rete con Nmap per identificare host attivi, porte aperte e servizi in esecuzione su metasploitable.
- Avviare scansioni di vulnerabilità automatizzate tramite Nessus sempre su metasploitable ed analizzare i risultati.

CONFIGURAZIONE LABORATORIO

L'esercizio ha richiesto la creazione di un laboratorio di test tramite macchine virtuali su Virtual Box grazie al collegamento di 3 macchine: Kali che fa da attaccante, metasploitable2 la vittima e PfSense il router di collegamento.

SCANSIONE TRAMITE NMAP

La scansione tramite Nmap avviene in CLI della kali, dove deve essere eseguito il seguente comando:

```
(kali@kali)-[~]
$ sudo nmap -sV -sS -oA scan_metasploitable 192.168.50.101
```

- -sV permette di rilevare la versione dei servizi.
- -sS identifica le porte aperte.
- -oA stampa un report su 3 formati diversi a nome di scan_metasploitable.
- IP della metasploitable.

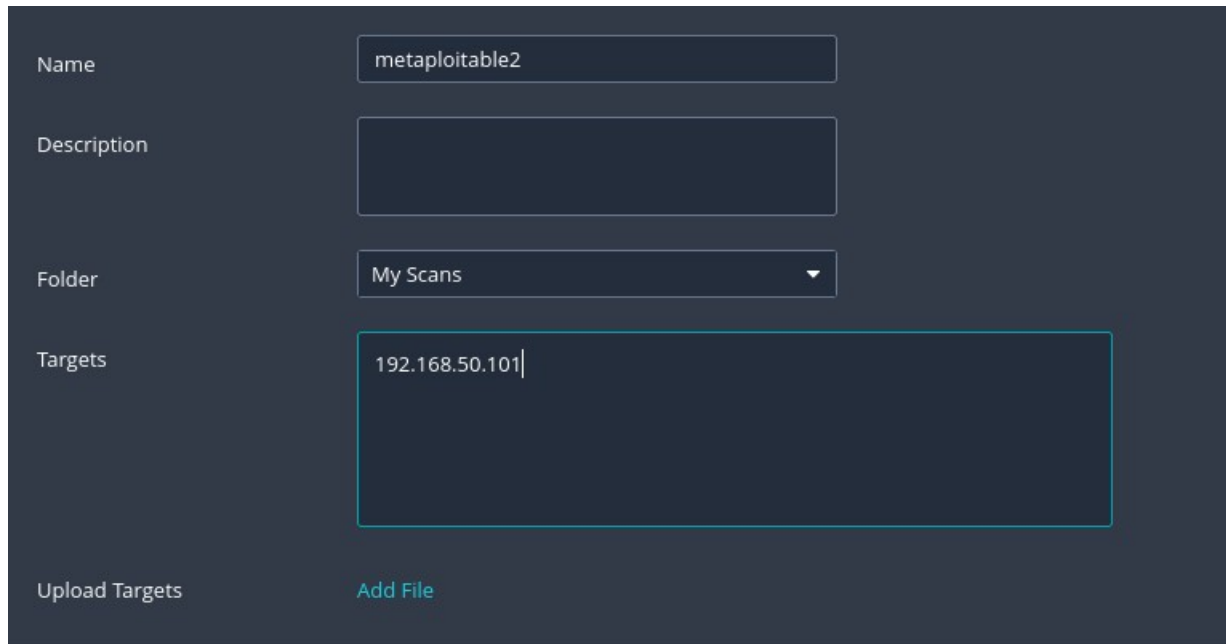
```
(kali@kali)-[~]
$ sudo nmap -sV -sS -oA scan_metasploitable 192.168.50.101
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-09 09:03 -0400
Nmap scan report for 192.168.50.101
Host is up (0.021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Subuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

SCANSIONE TRAMITE NESSUS

Al contrario di Nmap, Nessus è un software che ha una sua interfaccia grafica gestibile dal browser tramite questo comando `https://IP_della_kali:8834/` dopo averlo installato e configurato da linea di comando.

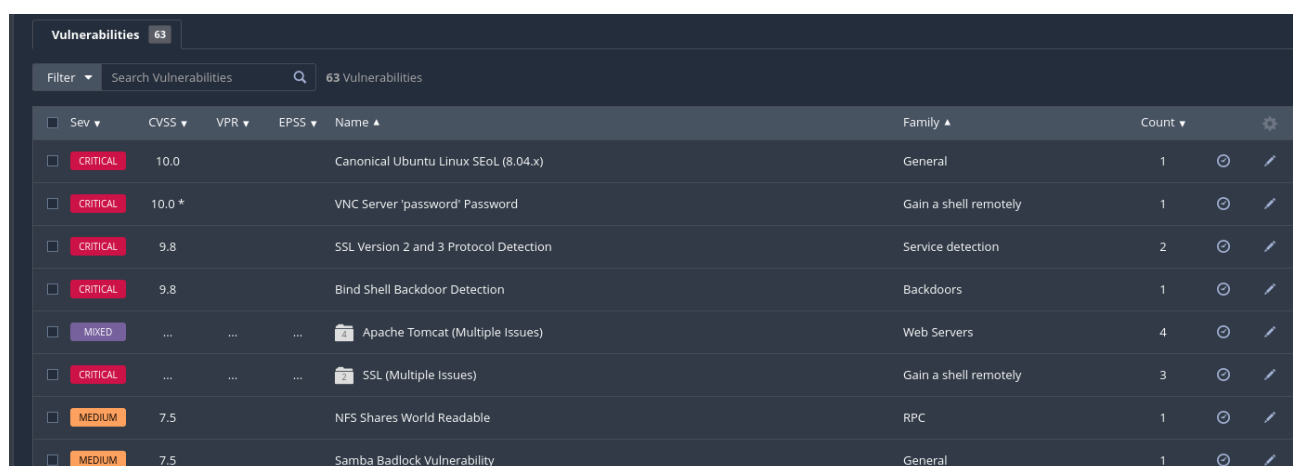
Una volta avuto l'accesso si inizia la scannerizzazione scegliendo basic network scan.



The screenshot shows the Nessus scan configuration interface. It includes the following fields and controls:

- Name:** A text input field containing "metasploitable2".
- Description:** An empty text input field.
- Folder:** A dropdown menu currently set to "My Scans".
- Targets:** A large text area containing the IP address "192.168.50.101".
- Buttons:** "Upload Targets" and "Add File" are located at the bottom left.

Il nome è a scelta per comodità e ho inserito metasploitable2 e in Target mettere l'IP della vittima.



The screenshot shows the "Vulnerabilities" page in Nessus, displaying a list of 63 detected vulnerabilities. The table includes columns for severity, CVSS score, VPR, EPSS, name, family, and count.

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
MEDIUM	7.5			NFS Shares World Readable	RPC	1
MEDIUM	7.5			Samba Badlock Vulnerability	General	1

ANALISI NMAP

La scansione ha individuato 23 porte attive attaccabili su 1000 scansionate. Denotando un'ampia superficie d'attacco. Già da questa prima analisi si possono individuare protocolli vulnerabili come l'FTP sulla porta 21, mancante della crittografia permettendo il Man-in-the-middle. La porta 80 è un altro punto critico essendo anch'essa mancante della crittografia. Saltano all'occhio anche il protocollo telnet e netbios entrambi ampiamente superati e sconsigliati, poiché non seguono gli attuali protocolli di sicurezza, infatti espongono facilmente le credenziali e le informazioni della rete.

ANALISI NESSUS

Nessus al contrario di Nmap fa un'analisi più profonda rilevando le vulnerabilità della rete con le relative descrizioni e soluzioni. Il Software ha individuato 63 vulnerabilità di cui 9 critiche:



Vulnerabilità critiche:

Canonical Ubuntu Linux SEoL (8.04.x)

Descrizione

In base alla versione rilevata, il sistema operativo in uso è Canonical Ubuntu Linux 8.04.x. Di conseguenza, questo prodotto non è più supportato o mantenuto dal produttore o dal fornitore.

La mancanza di supporto implica che il produttore non rilascerà più nuove patch di sicurezza per il prodotto. Di conseguenza, il sistema può contenere molteplici vulnerabilità di sicurezza note e non risolte.

Soluzione

Eseguire l'aggiornamento (upgrade) a una versione di Canonical Ubuntu Linux che sia attualmente supportata dal produttore.

VNC Server 'password' Password

Descrizione

Il server VNC in esecuzione sull'host remoto è protetto da una password debole. Nessus è stato in grado di effettuare l'accesso (login) utilizzando l'autenticazione VNC e la password '**password**'. Un attaccante remoto non autenticato potrebbe sfruttare questa debolezza per assumere il controllo totale del sistema.

Soluzione

Proteggere il servizio VNC impostando una password robusta (strong password).

SSL Version 2 and 3 Protocol Detection

Descrizione

Il servizio remoto accetta connessioni cifrate che utilizzano i protocolli SSL 2.0 e/o SSL 3.0. Queste versioni di SSL sono affette da diverse falle crittografiche, tra cui:

- Un sistema di imbottitura (*padding scheme*) non sicuro con i cifrari CBC.
- Sistemi di rinegoziazione e ripristino della sessione non sicuri.

Un attaccante può sfruttare queste falle per condurre attacchi di tipo Man-in-the-Middle (MitM) o per decifrare le comunicazioni tra il servizio interessato e i client.

Sebbene i protocolli SSL/TLS dispongano di un meccanismo sicuro per negoziare la versione più alta supportata (facendo in modo che queste vecchie versioni vengano utilizzate solo se il client o il server non supportano di meglio), molti browser web implementano

questa funzione in modo non sicuro. Ciò consente a un attaccante di forzare il downgrade della connessione a una versione inferiore (come avviene, ad esempio, nell'attacco POODLE). Pertanto, si raccomanda di disattivare completamente questi protocolli.

Il NIST ha stabilito che il protocollo SSL 3.0 non è più accettabile per le comunicazioni sicure. Inoltre, a partire dalla data di entrata in vigore dello standard PCI DSS v3.1, qualsiasi versione di SSL non soddisfa più la definizione di "crittografia forte" (*strong cryptography*) stabilita dal PCI SSC.

Soluzione

Consultare la documentazione dell'applicazione per disabilitare i protocolli SSL 2.0 e SSL 3.0.

Utilizzare al loro posto il protocollo TLS 1.2 (con suite di cifratura approvate) o versioni superiori.

Bind Shell Backdoor Detection

Descrizione

Una shell di comando è in ascolto sulla porta remota senza che sia richiesta alcuna autenticazione. Un attaccante potrebbe utilizzarla connettendosi alla porta remota e inviando direttamente dei comandi di sistema.

Soluzione

Verificare se l'host remoto è stato compromesso e, se necessario, reinstallare completamente il sistema operativo.

Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)

Description

The remote x509 certificate on the remote SSL server has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Descrizione

La chiave host SSH remota è stata generata su un sistema Debian o Ubuntu affetto da un bug nel generatore di numeri casuali della sua libreria OpenSSL.

Il problema è dovuto al fatto che un manutentore dei pacchetti Debian ha rimosso quasi tutte le fonti di entropia (casualità) nella versione remota di OpenSSL.

Un attaccante può facilmente ricavare la parte privata della chiave remota e utilizzarla per decifrare la sessione remota o per mettere in atto un attacco di tipo Man-in-the-Middle (MitM).

Soluzione

Considerare completamente vulnerabile e indovinabile (*guessable*) tutto il materiale crittografico generato sull'host remoto. In particolare, tutte le chiavi relative a servizi SSH, SSL e OpenVPN devono essere rigenerate da zero.

CONCLUSIONE

Mentre Nmap interroga tramite protocolli TCP o UDP la superficie d'attacco individuando le porte utilizzabili e avere un informazione sui programmi e le versioni presenti su quelle porte, Nessus va più in profondità usando dei plugin, che permettono di individuare le vulnerabilità e per ognuna ricavare una descrizione e le possibili soluzioni grazie ad un vasto database di CVE. Questi

strumenti sono importantissimi per un pentester, infatti usati insieme permettono un'analisi completa della rete e le sue vulnerabilità rendendo più semplice e efficace la fase di exploitation.

Le analisi effettuate in questo test permettono di avere una buona panoramica della metasploitable, che risulta poco sicura e ricca di falle, ma era ampiamente previsto poiché trattasi di una macchina volutamente vulnerabile per laboratori di cybersecurity.